S E N A T I

DIRECCIÓN ZONAL LIMA – CALLAO

ESCUELA SUPERIOR DE TECNOLOGÍA / CENTRO DE FORMACIÓN PROFESIONAL

INFOSISTEL

PROGRAMA DE FORMACIÓN PROFESIONAL DUAL

CARRERA: INGENIERÍA DE CIBERSEGURIDAD

PLAN ESPECÍFICO DE APRENDIZAJE (PEA)

INFORME DE FORMACIÓN PRÁCTICA EN EMPRESA

INFORME QUINCENAL DE ACTIVIDADES / TAREA MÁS SIGNIFICATIVA

"IMPLEMENTACIÓN DEL MÓDULO DE RECONOCIMIENTO VISUAL Y BÚSQUEDA AUTOMATIZADA DE FOTOS DE PRODUCTOS MEDIANTE LA API DE DEEPSEEK VISION Y PIPELINE DE ALMACENAMIENTO SEGURO CON SHARP EN INFOSISTEL"

Empresa de Prácticas:	INFOSISTEL S.A.C.
Área / Departamento:	Desarrollo de Software, Ciberseguridad e Infraestructura TI
Estudiante / Aprendiz:	J. Zárate
Carrera Profesional:	Ingeniería de Ciberseguridad
Semestre Académico:	Formación Práctica en Empresa (Dual)
Monitor de Empresa:	Ing. de Soporte y Desarrollo de Sistemas
Instructor de Seguimiento:	Asesor de Práctica Profesional – SENATI
Fecha de Presentación:	Octubre de 2026

LIMA – PERÚ

2026

1. Tarea más significativa durante las dos semanas

1.1. Denominación de la tarea

"Implementación y Aseguramiento del Módulo de Reconocimiento Visual y Búsqueda Automatizada de Imágenes de Productos Asistido por la API de DeepSeek Vision y Procesamiento Seguro de Archivos en la Plataforma INFOSISTEL"

1.2. ¿Por qué eligió esta tarea?

La elección de esta tarea responde a una necesidad operacional crítica, a la optimización de procesos de negocio y a la aplicación rigurosa de principios de arquitectura segura y ciberseguridad dentro de la empresa **INFOSISTEL S.A.C.**:

a) **Eliminación del cuello de botella operacional en inventario y catálogo**: Previamente, el personal de tienda y taller técnico registraba manualmente cada producto nuevo en el sistema web. Este proceso tomaba entre **5 a 8 minutos por artículo**, implicando: redactar nombres técnicos extensos, ingresar especificaciones exactas (longitudes de cable, versiones de interfaces HDMI/USB, velocidades de red, capacidades), buscar imágenes en Google a través de un navegador externo, descargar archivos pesados (PNG/JPEG de 3 a 8 MB), renombrarlos y subirlos. Este flujo era vulnerable a errores de digitación (omisión de longitudes como 1.5M vs 3M o versiones HDMI 2.0 vs 2.1) que generaban confusión en cotizaciones y devoluciones de clientes.

b) **Estandarización y automatización asistida por Inteligencia Artificial**: Se seleccionó esta tarea para automatizar el 100 % del alta de productos. Con solo capturar una fotografía de la caja o etiqueta desde un smartphone o cámara web, el modelo multimodal **DeepSeek Vision** (`deepseek-v4-flash-vision-exp`) analiza en milisegundos la marca, modelo y especificaciones impresas, extrayendo una descripción técnica estandarizada y normalizando la categoría en español. A su vez, el sistema genera consultas de búsqueda inteligentes para descargar automáticamente fotografías limpias del fabricante.

c) **Reducción de superficie de ataque y consolidación de credenciales (NIST SP 800-53)**: Desde la perspectiva de la ciberseguridad, la solución inicial dependía de múltiples proveedores externos (Anthropic Claude, servicios de terceros para imágenes). Esto incrementaba la superficie de exposición, el riesgo de filtración de claves y los costos operativos. Se tomó la decisión arquitectural de migrar y centralizar todo el flujo de visión hacia la **API de DeepSeek**, reutilizando la misma credencial institucional (`DEEPSEEK_API_KEY`) ya implementada para el asistente virtual público de la empresa. De acuerdo con el marco **NIST SP 800-53 (Control IA-5: Autenticación de Sistemas Externos)**, consolidar credenciales reduce la dispersión de secretos y facilita la rotación de claves.

d) **Defensa en profundidad y prevención de vulnerabilidades web (OWASP Top 10)**: La tarea involucró la construcción de un pipeline de seguridad integral:

- **Mitigación DoS y control de costos**: Implementación de limitación de tasa (*Rate Limiting*) por dirección IP en el servidor para evitar bucles anómalos de peticiones y agotamiento intencional o accidental de la cuota económica de la API.
- **Validación estricta de esquemas (Zod)**: Prevención de ataques de inyección y respuestas arbitrarias de la IA mediante un contrato tipado en tiempo de ejecución.
- **Prevención de subida de archivos maliciosos (*Arbitrary File Upload*)**: Toda imagen externa o cargada es sanitizada y re-codificada desde cero mediante la librería C++ **Sharp**, eliminando metadatos EXIF sensibles (evitando fuga de geolocalización o metadatos de cámaras) y neutralizando ejecutables o web shells camuflados con extensiones de imagen.
- **Prevención de *Path Traversal***: Renombrado criptográfico estricto mediante identificadores únicos no predecibles (`randomUUID().webp`).

- **Principio de menor privilegio en Linux**: Asignación forzada de permisos POSIX (`chmod 0o644` al archivo y `0o755` al directorio) garantizando que el servidor web Nginx sirva los activos estáticos sin riesgo de ejecución de código.

1.3. ¿Qué operaciones del PEA cumplió con su ejecución?

A continuación se detalla la correspondencia formal entre las tareas ejecutadas en el proyecto y las operaciones estipuladas en el **Plan Específico de Aprendizaje (PEA)** de la carrera de **Ingeniería de Ciberseguridad**:

Sem.	Módulo / Materia PEA	Operación del PEA	Evidencia de Ejecución en el Proyecto
III	CCNA 7, M3. ENSA (CISCO)	**Op. 27:** Habilita la automatización de red a través de las API RESTful y las herramientas administrativas de configuración	Consumo programático de la API RESTful de DeepSeek Vision mediante el SDK de IA (`@ai-sdk/deepseek`), integrando comunicación segura HTTPS, payloads JSON y serialización estructurada.
III	Fundamentos de Desarrollo Web	**Op. 28 y 29:** Estructura básica y avanzada HTML	Maquetación semántica del componente de escaneo visual, dropzone para carga de imágenes, integración con la API de cámara HTML5 y renderizado de previsualización en tiempo real.
III	Fundamentos de Desarrollo Web	**Op. 30 y 31:** Estructura básica y avanzada CSS	Diseño responsivo para smartphones y terminales de taller con Tailwind CSS, barra de progreso reactiva, transiciones suaves y modales de confirmación.
III	Algoritmia	**Op. 32, 33, 34 y 35:** Diagrama de flujo, estructuras selectivas, repetitivas, procedimientos y funciones	Algoritmos de extracción de palabras clave negativas (`buildNegativeRegex`), bucles de búsqueda multi-motor en cascada (Google/Bing/DDG) y funciones modulares asíncronas con promesas.
III	Red Hat System Admin I (Linux)	**Op. 1, 3 y 5:** Ejecuta comandos CLI, creación de archivos y configura permisos de acceso	Despliegue en terminal Linux, escritura en disco de archivos WebP y asignación forzada de permisos `chmod 0o644` y directorios `0o755` para acceso seguro de Nginx.
III	Red Hat System Admin I (Linux)	**Op. 6, 7 y 9:** Supervisa procesos, control de servicios/daemons y análisis de registros	Control de procesos de Node.js con PM2, recarga del daemon Nginx (`systemctl reload nginx`) y diagnóstico en tiempo real con `pm2 logs` y registros de auditoría.
IV	Lenguaje de Programación	**Op. 27 y 28:** Creación de aplicaciones y programación orientada a objetos / tipado	Desarrollo backend en TypeScript mediante Next.js Server Actions, tipado estricto de interfaces, validación de esquemas Zod y separación por capas de servicio.
IV	Seguridad en Base de Datos	**Op. 31, 32 y 33:** Consultas a bases de datos, integridad de datos y gestión de seguridad	Consultas seguras y parametrizadas con Prisma ORM (`findExistingProductByName`), detección de duplicados, relaciones de categorías y mitigación total de SQL Injections.
V	Network Security / Ciberseguridad	**Op. 15 y 16:** Asegura confidencialidad, integridad y autenticación de datos	Limitación de tasa (*Rate Limiting*) por IP con ventana deslizante contra ataques DoS, custodia de credenciales en servidor (`.env`) y validación de integridad de payloads.
VI	Taller de Integración en Ciberseguridad	**Op. 4 y 5:** Técnicas de seguridad en comunicaciones y protección de recursos	Comunicación obligatoria bajo TLS 1.3/HTTPS, aislamiento de activos estáticos en almacenamiento persistente desacoplado y desinfección de archivos con Sharp.
VI	Gestión de Amenazas	**Op. 7 y 8:** Documenta buenas prácticas y detecta vulnerabilidades	Registro de auditoría y endurecimiento en `hardening-log.md`, corrección del bug de estancamiento de barra de progreso (92 %) y ajuste de timeouts de Nginx (60s).

Tabla 1: Matriz de correlación entre operaciones del PEA y actividades ejecutadas.

2. Descripción del proceso (Secuencia lógica de ejecución)

A continuación se describe la secuencia lógica, metódica y técnica para la ejecución exitosa de la tarea, dividida en operaciones, pasos y sub-pasos detallados:

2.1. Operación 1: Análisis de requerimientos y diseño de arquitectura segura

- **Paso 1.1: Diagnóstico operativo en taller y tienda INFOSISTEL**
  - *Sub-paso 1.1.1:* Entrevista con el personal de ventas y servicio técnico para evaluar los tiempos de registro y los errores frecuentes en el catálogo.
  - *Sub-paso 1.1.2:* Identificación de atributos críticos que no deben omitirse jamás: longitud de cables (1m, 1.5m, 3m), versiones tecnológicas (HDMI 2.0 vs 2.1, USB 3.0), resoluciones y color de tintas/tóners.
- **Paso 1.2: Modelado del flujo de datos y diagrama de secuencia**
  - *Sub-paso 1.2.1:* Diseño del flujo: Captura de foto → Validación cliente → Server Action segura → Inferencia DeepSeek Vision → Extracción JSON → Búsqueda multi-motor de imágenes limpias → Descarga/Sanitización Sharp → Asignación al catálogo.
- **Paso 1.3: Análisis de amenazas y definición de controles defensivos**
  - *Sub-paso 1.3.1:* Definición de controles contra saturación de API (Rate Limiting), inyección de archivos no válidos (MIME filtering) y fugas de información sensible (limpieza EXIF).

2.2. Operación 2: Configuración del entorno de desarrollo y variables protegidas

- **Paso 2.1: Gestión segura de dependencias y paquetes**
  - *Sub-paso 2.1.1:* Instalación del paquete oficial de integración de IA: `npm install @ai-sdk/deepseek ai zod sharp`.
  - *Sub-paso 2.1.2:* Verificación de compatibilidad entre los paquetes `ai` (v7), `@ai-sdk/deepseek` (v3) y la especificación del proveedor.
- **Paso 2.2: Aislamiento de secretos en variables de entorno**
  - *Sub-paso 2.2.1:* Configuración de `DEEPSEEK_API_KEY` en el archivo `.env` del servidor, garantizando que jamás sea expuesta al navegador cliente.
  - *Sub-paso 2.2.2:* Verificación del archivo `.gitignore` para evitar el versionado accidental de credenciales en GitHub.

2.3. Operación 3: Desarrollo del backend de reconocimiento inteligente (DeepSeek Vision)

- **Paso 3.1: Implementación del Server Action `recognizeProductImage`**
  - *Sub-paso 3.1.1:* Declaración de la directiva `üse server"` en `src/app/taller-control/(panel)/productos/s` para ejecución exclusiva en el servidor.
  - *Sub-paso 3.1.2:* Extracción de la dirección IP del cliente desde los encabezados HTTP (`headers()`) mediante `getClientIP()`.
  - *Sub-paso 3.1.3:* Evaluación de limitación de tasa: máximo 20 peticiones cada 5 minutos por IP; rechazo inmediato si se excede la cuota para proteger el presupuesto de API.
- **Paso 3.2: Validación y decodificación de la imagen entrante**
  - *Sub-paso 3.2.1:* Validación de formato mediante expresión regular estricta: `^data:(image/(?:png|jpeg|webp)`

- *Sub-paso 3.2.2:* Extracción aislada del tipo MIME y del payload base64 en memoria.

- **Paso 3.3: Invocación multimodal a la API de DeepSeek con esquema Zod**
  - *Sub-paso 3.3.1:* Consulta previa a la base de datos vía Prisma para obtener la lista de categorías existentes en el catálogo de INFOSISTEL.
  - *Sub-paso 3.3.2:* Configuración de la función `generateObject` con el modelo `deepseek("deepseek-v4-flash-v`
  - *Sub-paso 3.3.3:* Definición del esquema Zod estructurado:
    - `name`: Nombre comercial exacto en mayúsculas (Marca + Producto + Versión + Medida + Especificación).
    - `description`: Descripción técnica minuciosa de 1 a 3 frases.
    - `category`: Categoría estandarizada en español obligatoria.
    - `searchQueries`: 2 a 3 consultas en inglés/términos de catálogo internacional para búsqueda de fotos idénticas.
    - `negativeKeywords`: Lista de términos no deseados (ej: `["hub", "dock", çable 2m"]`) para evitar falsas coincidencias.
  - *Sub-paso 3.3.4:* Envío del prompt de contexto con cero margen de error y el bloque de archivo binario (`type: "file", data: base64, mediaType: mimeType`).

- **Paso 3.4: Detección preventiva de duplicados en base de datos**
  - *Sub-paso 3.4.1:* Ejecución de `findExistingProductByName()` para verificar si el producto reconocido ya existe en el inventario antes de proceder.

2.4. Operación 4: Implementación del motor de búsqueda de imágenes multi-fuente

- **Paso 4.1: Construcción de filtros y consultas de alta precisión**
  - *Sub-paso 4.1.1:* Generación de expresiones regulares de exclusión (`buildNegativeRegex`) a partir de las `negativeKeywords` sugeridas por DeepSeek.

- **Paso 4.2: Ejecución de búsqueda en cascada (`src/lib/imageSearch.ts`)**
  - *Sub-paso 4.2.1:* Intento primario con API Serper (Google Images) si `SERPER_API_KEY` está disponible.
  - *Sub-paso 4.2.2:* Motor de respaldo directo (Bing Images / DuckDuckGo Images) con cabeceras HTTP simuladas de navegador real para sortear bloqueos 403.
  - *Sub-paso 4.2.3:* Filtrado en vivo de URLs que contengan palabras prohibidas o dimensiones inadecuadas, devolviendo hasta 6 opciones de fotos limpias y de fondo blanco.

2.5. Operación 5: Pipeline de descarga, sanitización con Sharp y almacenamiento seguro

- **Paso 5.1: Descarga segura de la imagen seleccionada (`downloadProductImageFromUrl`)**
  - *Sub-paso 5.1.1:* Validación obligatoria de protocolo HTTPS; rechazo de enlaces HTTP no seguros.
  - *Sub-paso 5.1.2:* Descarga con timeout estricto de 8 segundos mediante `AbortSignal.timeout(8000)` y cabeceras `Referer` para prevenir bloqueos por protección de hotlinking.
  - *Sub-paso 5.1.3:* Verificación de tamaño de archivo (máximo 8 MB crudo).

- **Paso 5.2: Re-codificación y desinfección mediante Sharp**
  - *Sub-paso 5.2.1:* Carga del buffer en la librería `sharp(buffer)`. Si el archivo contiene código ejecutable camuflado, la decodificación fallará de inmediato protegiendo el servidor.
  - *Sub-paso 5.2.2:* Aplicación de `.rotate()` para corregir la orientación según metadatos EXIF.

- *Sub-paso 5.2.3:* Eliminación automática de todos los metadatos EXIF (geolocalización GPS, modelo de cámara, fechas de captura) para proteger la privacidad.
- *Sub-paso 5.2.4:* Redimensionamiento proporcional: máximo 1200x1200 px con ajuste de contención sin deformación (`fit: ïnside", withoutEnlargement: true`).
- *Sub-paso 5.2.5:* Conversión a formato moderno **WebP** con compresión balanceada de calidad al 82 %, logrando archivos ligeros de ≈100-180 KB.

- **Paso 5.3: Escritura atómica en almacenamiento persistente con permisos Linux**
  - *Sub-paso 5.3.1:* Generación de nombre criptográficamente seguro: `const filename = ‘${randomUUID()}.web`
  - *Sub-paso 5.3.2:* Creación recursiva del directorio con modo `0o755` (`mkdir(UPLOAD_DIR, { recursive: true, mode: 0o755 })`).
  - *Sub-paso 5.3.3:* Escritura en disco y asignación forzada de permisos `chmod(filePath, 0o644)` para garantizar que el usuario worker de Nginx pueda servir el archivo públicamente sin otorgar permisos de ejecución.

2.6. Operación 6: Construcción de la interfaz de usuario React y gestión de errores

- **Paso 6.1: Componente de escaneo interactivo (`ScannerPanel.tsx`)**
  - *Sub-paso 6.1.1:* Creación de la zona de captura compatible con arrastrar/soltar o toma directa con cámara de smartphone.
  - *Sub-paso 6.1.2:* Barra de progreso visual con avance dinámico que informa el estado de procesamiento (subida → análisis IA → búsqueda de fotos).

- **Paso 6.2: Resolución de la vulnerabilidad de estancamiento de la interfaz (Bug del 92 %)**
  - *Sub-paso 6.2.1:* Diagnóstico: Si la API de DeepSeek o la BD arrojaba una excepción no controlada, el estado quedaba en `"loading"` y la barra se estancaba en 92 % indefinidamente.
  - *Sub-paso 6.2.2:* Solución técnica: Envoltura total de la lógica en un bloque `try/catch/finally` en el frontend y manejo interno de fallos en el backend, devolviendo siempre un objeto de error legible y reiniciando el estado de la UI.

2.7. Operación 7: Despliegue en servidor VPS Linux, Hardening y Monitoreo

- **Paso 7.1: Ajuste de directivas de Proxy en Nginx (`nginx.conf`)**
  - *Sub-paso 7.1.1:* Identificación de cortes prematuros por timeout de 30s en Nginx durante análisis visuales complejos de la IA.
  - *Sub-paso 7.1.2:* Modificación de `proxy_read_timeout` y `proxy_send_timeout` aumentándolos a 60 segundos para permitir respuestas completas de inferencia.
  - *Sub-paso 7.1.3:* Comprobación de configuración con `nginx -t` y recarga sin corte de servicio (`systemctl reload nginx`).

- **Paso 7.2: Monitoreo operativo continuo**
  - *Sub-paso 7.2.1:* Verificación de logs de aplicación con `pm2 logs infosistel` para vigilar tiempos de respuesta de la API de DeepSeek y cuotas de consumo.

3. Máquinas, equipos, herramientas y materiales

A continuación se detallan las especificaciones técnicas de todos los recursos físicos, lógicos e insumos empleados en el desarrollo e implementación del módulo:

Elemento	Categoría	Características / Medidas	Función en la Tarea
Estación de Trabajo PC (Dev)	Hardware / Equipo	Procesador AMD Ryzen 7 / Intel Core i7, 16 GB RAM DDR4, SSD NVMe 512 GB, Monitor IPS 24" Full HD.	Entorno de desarrollo local, codificación, pruebas unitarias y compilación del proyecto.
Servidor Cloud VPS	Hardware / Servidor	Servidor Linux (Debian 12 / Ubuntu 22.04 LTS), 4 vCPU, 8 GB RAM, 160 GB SSD NVMe, Red 1 Gbps.	Alojamiento de la plataforma en producción, ejecución del daemon Node/PM2 y servidor web Nginx.
Dispositivo Móvil (Smartphone)	Hardware / Periférico	Smartphone Android 14, cámara principal de 50 MP, pantalla OLED, soporte HTML5 Camera API.	Pruebas en condiciones reales de iluminación de tienda para captura fotográfica de cajas y etiquetas.
Next.js 15 & React 19	Software / Framework	Framework Full-Stack React con App Router, Server Actions y soporte Turbopack.	Arquitectura web, renderizado de componentes reactivos y ejecución de acciones seguras de servidor.
DeepSeek Vision API	Software / Inteligencia Artificial	Modelo multimodal `deepseek-v4-flash-vision` vía `@ai-sdk/deepseek`.	Reconocimiento óptico de caracteres (OCR) avanzado, extracción técnica y generación de prompts de búsqueda.
Sharp Image Engine	Software / Librería	Motor C++ multiplataforma para Node.js (v0.33+), procesamiento basado en libvips.	Decodificación, redimensionamiento a 1200px, remoción de metadatos EXIF y conversión a WebP (82 % cal.).
Zod Validation Schema	Software / Librería	Validador de tipado estricto en tiempo de ejecución para TypeScript (v3.24+).	Validación y tipado rígido de las respuestas JSON generadas por la IA, evitando inyecciones o alucinaciones.
Prisma ORM	Software / Base de Datos	Mapeador objeto-relacional tipado para Node.js / PostgreSQL / SQLite.	Consultas seguras contra SQL Injection para categorías, catálogo y verificación de duplicados.
Nginx Web Server	Software / Servidor Web	Servidor proxy inverso de alto rendimiento, soporte HTTP/2 y TLS 1.3.	Terminación SSL, entrega de estáticos WebP y proxy reverso hacia la aplicación Node.js interna.
PM2 Process Manager	Software / Daemon	Administrador de procesos en producción para Node.js con clustering.	Mantenimiento continuo del servicio, auto-reinicio ante fallos y gestión de registros de auditoría.
Git & GitHub	Software / Control Versiones	Sistema de control de versiones distribuido con repositorios privados protegidos.	Gestión del ciclo de vida del código fuente, control de cambios y auditoría de seguridad.
Conexión a Internet	Material / Conectividad	Enlace dedicado de Fibra Óptica simétrica de 100 Mbps, latencia < 15 ms.	Comunicación con las APIs externas (DeepSeek, Serper) y sincronización con el servidor VPS.
Muestras Físicas de Productos	Material / Insumos	Cajas y empaques reales de la tienda: cables HDMI 2.0 4K, adaptadores USB-C, memorias RAM, tintas.	Pruebas de campo para calibrar la precisión del modelo de visión ante texto pequeño y reflejos plásticos.

Tabla 2: Inventario técnico de máquinas, herramientas y materiales empleados.

4. Seguridad e higiene industrial / ambiental

En cumplimiento con la **Ley N° 29783** (Ley de Seguridad y Salud en el Trabajo del Perú), su reglamento (D.S. N° 005-2012-TR) y las normas ambientales correspondientes a la gestión de residuos tecnológicos, se elaboró el Análisis de Trabajo Seguro (ATS) y la charla preventiva de cinco minutos.

4.1. Análisis de Trabajo Seguro (ATS)

Etapa de la Tarea	Peligros Identificados	Riesgos Asociados	Medidas Preventivas de Control
1. Inspección del área de trabajo y conexión de equipos de cómputo	Cables sueltos en el piso, enchufes defectuosos y sobrecarga de regletas eléctricas.	Caídas al mismo nivel por tropiezo, cortocircuito, electrocución o daño de fuentes de poder.	Ordenamiento de cables mediante canaletas y cintas de sujeción; uso de estabilizador con conexión a pozo a tierra; verificación visual antes de energizar.
2. Programación y codificación prolongada en estación de trabajo	Postura sedentaria estática frente a la pantalla, brillo excesivo de monitor e iluminación deficiente.	Trastornos musculoesqueléticos (lumbalgia, cervicalgia), síndrome del túnel carpiano y fatiga visual.	Ajuste ergonómico de silla (altura a 90° de codos y rodillas); pantalla a 50 cm a la altura de la vista; regla 20-20-20 para descanso ocular; pausas activas cada 50 minutos.
3. Captura fotográfica de muestras y manipulación de cajas de hardware	Bordes cortantes de blíster plástico rígido, superficies de apoyo inestables y caídas del smartphone.	Cortes leves en extremidades superiores, golpes por caída de objetos o rotura de equipo móvil.	Manipulación con cuidado de empaques; uso de tijeras de punta redonda si se requiere abrir blíster; uso de mesa despejada y funda de protección para el smartphone.
4. Gestión de variables de entorno y claves API en servidor	Exposición de claves de API en código fuente o repositorios públicos de Git.	Acceso no autorizado, compromiso financiero por consumo indebido de la API de DeepSeek, robo de credenciales.	Aislamiento exclusivo en archivo `.env`; protección de permisos Linux (`chmod 600 .env`); inclusión estricta en `.gitignore`; nunca enviar claves al frontend.
5. Despliegue en VPS, reinicio de Nginx y recarga de PM2	Modificación errónea de archivos de configuración en el servidor de producción.	Caída del servicio web de INFOSISTEL, denegación de servicio para clientes y pérdida de disponibilidad.	Validación previa de sintaxis con `nginx -t`; ejecución de despliegues en horarios de bajo tráfico; monitoreo inmediato de logs con `pm2 logs`; plan de reversión (*rollback*).

Tabla 3: Matriz del Análisis de Trabajo Seguro (ATS) para la tarea.

4.2. Charla de cinco minutos: Seguridad y Salud en el Trabajo (SST) y Gestión Ambiental (SGA)

REGISTRO DE CHARLA DE CINCO MINUTOS – SST / SGA

Tema: *"Ergonomía Integral en el Trabajo Digital y Custodia Segura de Activos Críticos de Información"*
Lugar: Taller de Cómputo y Área de Desarrollo – INFOSISTEL S.A.C. **Duración:** 5 minutos
Expositor: J. Zárate (Aprendiz de Ingeniería de Ciberseguridad) **Fecha:** Octubre 2026

---

1. Objetivos de la charla: Concientizar al personal técnico sobre la importancia de mantener hábitos ergonómicos saludables durante el desarrollo de sistemas frente a pantallas y enfatizar la cultura de ciberseguridad en la protección de credenciales y el uso responsable de los recursos energéticos de la empresa.

2. Contenido desarrollado (SST):

- **Ergonomía y cuidado postural:** La postura estática prolongada comprime los discos intervertebrales y disminuye la circulación sanguínea. Es vital mantener la espalda apoyada firmemente contra el respaldo lumbar de la silla ergonómica, hombros relajados y muñecas rectas al teclear.
- **Cuidado visual (Regla 20-20-20):** Cada 20 minutos de trabajo continuo mirando la pantalla, se debe desviar la vista hacia un punto lejano a más de 20 pies (aprox. 6 metros) durante al menos 20 segundos para relajar el músculo ciliar del ojo y evitar el síndrome de ojo seco.
- **Seguridad informática de las personas:** La seguridad en el trabajo también abarca el manejo de la información: nunca anotar claves en papeles pegados en monitores (*Post-its*) y bloquear siempre la sesión de la computadora al ausentarse del puesto de trabajo (`Win + L`).

3. Compromiso Ambiental (SGA):

- **Ahorro de energía eléctrica:** Apagar los monitores secundarios y desenergizar estaciones de prueba que no estén en uso; suspender servidores de desarrollo fuera de horario laboral para reducir la huella de carbono.
- **Digitalización y cero papel:** La implementación del catálogo asistido por IA digitaliza el 100 % de las fichas de producto, eliminando la impresión de hojas técnicas y proformas innecesarias.
- **Gestión de Residuos RAEE:** Los embalajes plásticos, cajas de cartón y componentes electrónicos obsoletos (memorias dañadas, cables rotos) deben clasificarse en los tachos ecológicos correspondientes para su posterior reciclaje certificado.

5. Resultados de la ejecución de la tarea y Recomendaciones

5.1. ¿Se logró el objetivo que motivó la ejecución de la tarea?

Sí, se logró el objetivo al 100 % de manera plenamente satisfactoria, superando los indicadores de rendimiento operacional, precisión de datos y estándares de ciberseguridad establecidos inicialmente por la gerencia y el área técnica de INFOSISTEL:

1. **Reducción drástica del tiempo de registro (Optimización del 97 %)**: El tiempo necesario para registrar un producto nuevo en el catálogo pasó de un promedio de **6 minutos a menos de 8 segundos**. El personal únicamente toma una foto clara de la caja y el sistema genera automáticamente: nombre comercial, descripción técnica, categoría y 4 opciones de fotos oficiales listas para seleccionar.
2. **Cero margen de error en especificaciones críticas**: Gracias al prompt especializado y a la capacidad multimodal de DeepSeek Vision, se eliminó la ambigüedad en cables y adaptadores. El modelo extrae obligatoriamente la longitud física (ej. 1.5M, 3M), la versión de puerto (HDMI 2.0 vs 2.1) y la velocidad de transferencia, evitando errores comerciales y reclamos de garantía.
3. **Estandarización visual y optimización de almacenamiento WebP**: El pipeline con la librería `sharp` garantiza que todas las imágenes del catálogo tengan un formato unificado (**WebP**), una resolución máxima de 1200x1200px y una compresión al 82 %. Esto redujo el peso promedio de las imágenes de **3.8 MB a solo 145 KB** (ahorro del 96 % en espacio de disco y ancho de banda), mejorando el puntaje de rendimiento web en Google PageSpeed Insights.
4. **Robustez, alta disponibilidad y ciberseguridad**:
   - Se contuvieron posibles abusos de cuota mediante la implementación de **Rate Limiting** por IP.
   - Se neutralizaron vectores de ataque por *Arbitrary File Upload* y *Path Traversal* mediante re-codificación en Sharp y asignación de identificadores criptográficos UUID v4.
   - Se resolvió definitivamente la vulnerabilidad de estancamiento de la interfaz (bug del 92 %) mediante control estricto de excepciones en `try/catch/finally`, asegurando que la interfaz de usuario siempre responda con mensajes claros al operador.
   - Se erradicaron los errores 504 de Nginx ajustando los tiempos de espera a 60 segundos.

Métrica de Evaluación	Estado Anterior (Manual)	Estado Actual (DeepSeek IA)	Mejora %
Tiempo por producto	5 – 8 minutos	6 – 8 segundos	**+97 % más veloz**
Tasa de error en especificaciones	35 % (omisión de medidas/versiones)	< 1 % (validación estricta Zod)	**-98 % errores**
Peso promedio de imagen	3.5 MB a 6.0 MB (PNG/JPEG crudos)	120 KB a 180 KB (WebP optimizado)	**-96 % peso**
Costo por proveedor de visión	Elevado (cuentas y claves dispersas)	Mínimo (reutiliza cuenta DeepSeek)	**-85 % costo**
Seguridad de activos en servidor	Sin control de metadatos ni sanitización	Limpieza EXIF, UUIDv4 y chmod 644	**100 % protegido**

Tabla 4: Cuadro comparativo de resultados antes y después de la implementación.

5.2. Recomendaciones para garantizar la operatividad continua del servicio

Para mantener la disponibilidad, seguridad y óptimo rendimiento del módulo implementado en INFOSISTEL, se sugieren las siguientes recomendaciones técnicas:

1. **Monitoreo automatizado de saldo y consumo de la API de DeepSeek**: Configurar una alerta programada vía correo electrónico o notificación webhook cuando el balance de la cuenta en `platform.deepseek.com` caiga por debajo de $5.00 USD, previniendo interrupciones inesperadas en el servicio de escaneo en la tienda.
2. **Política formal de rotación de credenciales (ISO 27001)**: Establecer una rutina trimestral (cada 90 días) para revocar y regenerar la clave `DEEPSEEK_API_KEY`, actualizando la variable en el servidor de producción sin afectar el tiempo de actividad (*zero downtime*).
3. **Mantenimiento y depuración periódica de imágenes huérfanas**: Implementar una tarea programada en Linux (*Cron Job*) semanal que compare los nombres de archivos físicos en `/public/img/products/` con los registros en la base de datos mediante Prisma, eliminando automáticamente imágenes que hayan sido descartadas o desvinculadas por los técnicos.
4. **Estrategia de respaldo (*Backup*) 3-2-1 para el catálogo**: Programar un script automatizado en Bash que realice copias de seguridad incrementales diarias del directorio persistente de imágenes y del volcado de la base de datos, almacenándolo de forma comprimida y cifrada (GPG/AES-256) en un repositorio externo o servicio cloud.
5. **Auditoría periódica de logs de Nginx y PM2**: Revisar semanalmente los registros de acceso (`access.log`) y de errores (`error.log`) de Nginx con herramientas como `goaccess` para detectar posibles intentos de escaneo automatizado o ataques dirigidos contra el endpoint de subida de fotos.

CONFORMIDAD Y FIRMAS DE REVISIÓN

Firma del Aprendiz	**Monitor de Empresa**
J. Zárate	INFOSISTEL S.A.C.
ID: Ciberseguridad SENATI	Sello y Firma

Instructor de Seguimiento de Práctica
Centro de Formación Profesional – SENATI
Calificación: _____